

1

Lab

PHỤC VỤ MỤC ĐÍCH GIÁO DỤC
FOR EDUCATIONAL PURPOSE ONLY

Web Application Firewall

Thực hành môn An toàn mạng máy tính nâng cao

Tháng 3/2025

Lưu hành nội bộ

<Ng nghiêm cấm đăng tải trên internet dưới mọi hình thức>

A. TỔNG QUAN

1. Mục tiêu

- Tìm hiểu và triển khai một opensource Web Application Firewall – ModSecurity
- Hiểu cấu trúc rule của ModSecurity
- Tạo các custom rule trên ModSecurity
- Tìm hiểu cách áp dụng Machine Learning trong việc cải tiến WAF

2. Thời gian thực hành

- Thực hành tại lớp: 5 tiết tại phòng thực hành.
- Hoàn thành báo cáo kết quả thực hành: tối đa 13 ngày.

B. CHUẨN BỊ MÔI TRƯỜNG

- Máy tính/máy ảo Hệ điều hành Kali Linux (Tải xuống tại: <https://www.kali.org/get-kali/>)
- DVWA
- Modsecurity

C. THỰC HÀNH

1. Cài đặt và cấu hình DVWA

DVWA là viết tắt của Damn Vulnerable Web Application, một ứng dụng web PHP/MySQL chứa nhiều lỗ hổng đã biết

DVWA được thiết kế để giúp các nhà phát triển web và chuyên gia bảo mật tìm hiểu về bảo mật ứng dụng web.

a. Cài đặt và cấu hình DVWA Apache website

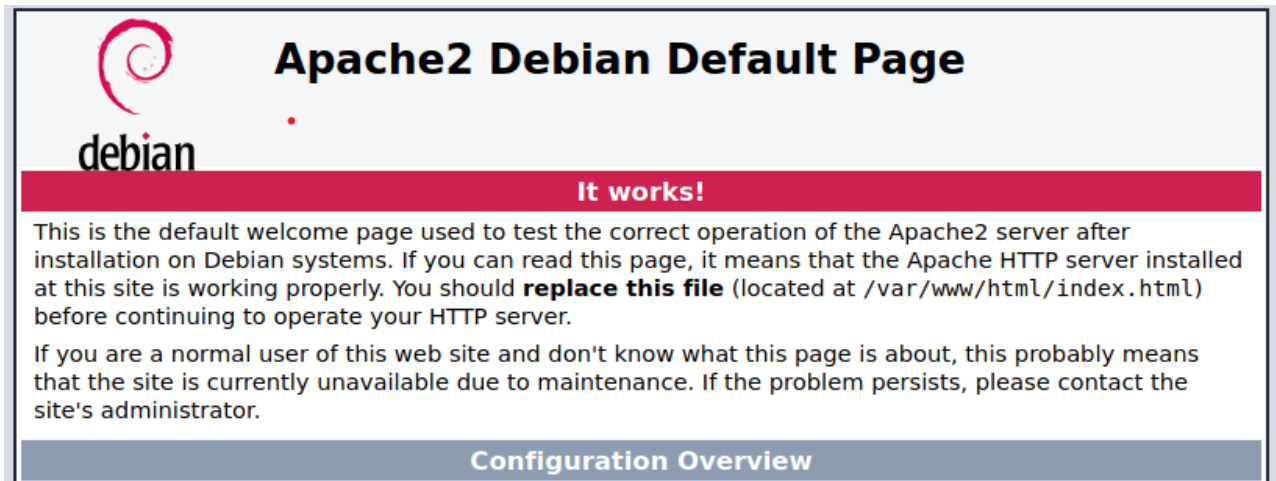
Để tải xuống source code DVWA, sử dụng Terminal thực thi các lệnh sau:

```
cd /var/www/html
git clone https://github.com/digininja/DVWA.git
sudo chmod 777 DVWA
```

Khởi động *apache2* service:

```
sudo service apache2 start
```

Sử dụng trình duyệt bất kỳ (Chrome, Firefox,...) truy cập vào địa chỉ to <http://127.0.0.1/> để kiểm tra Apache server đã triển khai thành công hay chưa.

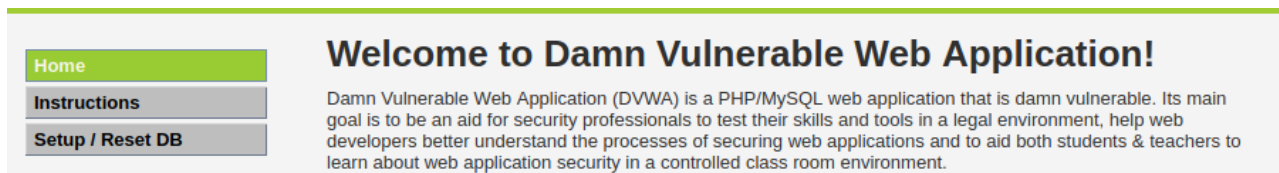


Hình 1 Apache server đã cài đặt và khởi động thành công

Thực thi các lệnh sau trong Terminal để cấu hình DVWA:

```
cd DVWA
sudo cp config/config.inc.php.dist config/config.inc.php
```

Truy cập vào đường dẫn <http://127.0.0.1/DVWA> trên trình duyệt. Bạn sẽ thấy trang Welcome Page:



Hình 2 Welcome page DVWA

b. Tạo DVWA user trong local database

Truy cập <http://127.0.0.1/DVWA/setup.php> Sau đó chọn **Create/Reset database** để tạo DVWA user.

Bây giờ DVWA đã sẵn sàng để tiến hành các thử nghiệm tấn công.

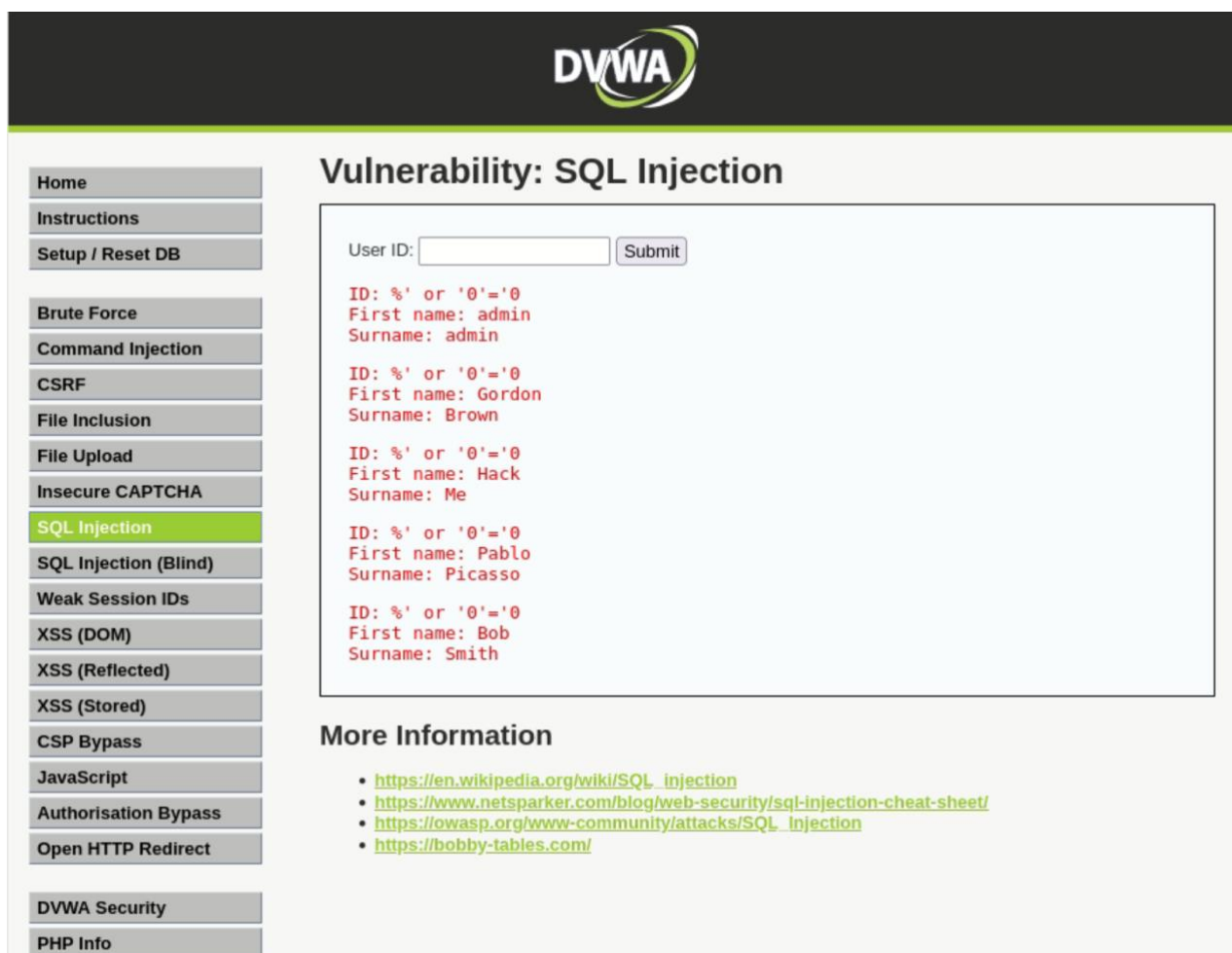
c. Thử nghiệm tấn công trên DVWA

DVWA cung cấp môi trường thử nghiệm các loại tấn công khác nhau. Dưới đây sẽ là hướng dẫn thực nghiệm tấn công SQL Injection.

Sau khi đăng nhập vào DVWA, tại thanh điều hướng, chọn SQL Injection. Tại ô User ID ta có thể nhập thông tin truy vấn.

Với các truy vấn thông thường, kết quả trả về là thông tin của User tương ứng với User ID. Để tấn công SQL Injection, thực hiện nhập câu lệnh truy vấn sau:

```
%' or '0'='0
```



DVWA

Vulnerability: SQL Injection

User ID:

ID: '%' or '0'='0
First name: admin
Surname: admin

ID: '%' or '0'='0
First name: Gordon
Surname: Brown

ID: '%' or '0'='0
First name: Hack
Surname: Me

ID: '%' or '0'='0
First name: Pablo
Surname: Picasso

ID: '%' or '0'='0
First name: Bob
Surname: Smith

More Information

- https://en.wikipedia.org/wiki/SQL_injection
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- https://owasp.org/www-community/attacks/SQL_injection
- <https://bobby-tables.com/>

Navigation Links:

- Home
- Instructions
- Setup / Reset DB
- Brute Force
- Command Injection
- CSRF
- File Inclusion
- File Upload
- Insecure CAPTCHA
- SQL Injection**
- SQL Injection (Blind)
- Weak Session IDs
- XSS (DOM)
- XSS (Reflected)
- XSS (Stored)
- CSP Bypass
- JavaScript
- Authorisation Bypass
- Open HTTP Redirect
- DVWA Security
- PHP Info

Task: Thực hiện các tấn công khác trên DVWA

2. ModSecurity Web Application Firewall

ModSecurity là tường lửa ứng dụng web (WAF) cung cấp lớp bảo mật bổ sung cho các ứng dụng web. Nó là một mô-đun mã nguồn mở dành cho Máy chủ HTTP Apache, IIS và Nginx giúp bảo vệ các trang web có lỗ hổng web (SQLi, XSS, Path Traversal, ...). Mô-đun này hoạt động bằng cách phân tích các yêu cầu HTTP đến và áp dụng một bộ quy tắc để xác định và chặn các cuộc tấn công tiềm ẩn. Các quy tắc này có thể được tùy chỉnh để đáp ứng các yêu cầu bảo mật cụ thể của trang web hoặc ứng dụng.

Các tính năng của ModSecurity:

- Ngăn chặn các cuộc tấn công vào ứng dụng web (hỗ trợ Apache)
- Mã nguồn mở
- Ghi nhật ký và giám sát
- Hỗ trợ SSL/TLS
- Quy tắc tùy chỉnh

Phương pháp triển khai:

- **Embedded:** triển khai cùng với Máy chủ Web (chỉ một VM)
- **Reverse Proxy:** riêng biệt như một nút đứng trước Web Server

a. Cài đặt ModSecurity

Cài đặt ModSecurity

```
sudo apt install libapache2-mod-security2 -y
sudo a2enmod headers
sudo systemctl restart apache2
```

Cấu hình ModSecurity theo tập tin cấu hình mẫu:

```
sudo cp /etc/modsecurity/modsecurity.conf-recommended /etc/modsecurity/modsecurity.conf
```

Sửa cấu hình tập tin /etc/modsecurity/modsecurity.conf. Thay đổi trường **SecRuleEngine** thành **On**

Khởi động lại apache server:

```
sudo systemctl restart apache2
```

b. Cấu hình Rule

ModSecurity sử dụng ModSecurity Rule Language rất linh hoạt để thiết lập các quy tắc.

Tham khảo hướng dẫn sử dụng ModSecurity Rule Language tại link

<https://github.com/owasp-modsecurity/ModSecurity/wiki/Reference-Manual-%28v3.x%29>

Trong nội dung bài thực hành này, chúng ta sẽ tham khảo bộ core rule OWASP sử dụng cho ModSecurity tại link: <https://github.com/coreruleset/coreruleset>

Để cấu hình rule cho ModSecurity, chúng ta có thể cấu hình trực tiếp tại tập tin

/etc/httpd/conf.d/mod_security.conf hoặc cấu hình rule thành một tập tin riêng biệt.

Để có thể cấu hình file riêng biệt, chúng ta cần thêm dòng sau vào để hệ thống include sang 1 file cấu hình khác: **Include “/đường dẫn file cần tham chiếu/tên_file.conf”**

Dưới đây là ví dụ cho file cấu hình /etc/httpd/conf.d/mod_security.conf với tập tin cấu hình rule được lưu trữ tại /usr/share/modsecurity-crs

```
<IfModule security2_module>
    SecDataDir /var/cache/modsecurity
    Include /usr/share/modsecurity-crs/crs-setup.conf
    Include /usr/share/modsecurity-crs/rules/*.conf
</IfModule>
```

Task: Sử dụng bộ Core rule OWASP cấu hình cho ModSecurity và demo ít nhất 3 hành động trái phép được phát hiện và chặn bởi ModSecurity. Tham khảo:

https://github.com/khangtictoc/DVWA_ModSecurity_Deployment

3. Mod Security Core Rule Set Problem:

Mod Security Core Rule Set là một công cụ quan trọng trong việc bảo vệ ứng dụng web trước các cuộc tấn công OWASP Top 10 bằng cách áp dụng các quy tắc được xác định trước để chặn các hành vi độc hại. Tuy nhiên, việc triển khai bộ Core Rule Set của Mod Security trong thực tế thường đối mặt với một số thách thức, trong đó có việc xảy ra các trường hợp False Positive - tức là các trường hợp mà hệ thống phát hiện và chặn nhầm các hoạt động không

phải là mối đe dọa thực sự. Nguyên nhân của hiện tượng này xuất phát từ cơ chế tính Anomaly score (điểm bất thường) của Core Rule Set.

Task: Tìm hiểu cơ chế hoạt động của việc tính điểm bất thường của bộ Core Rule Set và giải thích tại sao cơ chế này lại dẫn đến sự xuất hiện của False Positive. Tham khảo: https://coreruleset.org/docs/concepts/anomaly_scoring/

4. Improve Mod Security:

Do sự tồn tại của vấn đề về false positive khi sử dụng bộ Core Rule Set, có nhiều cách để điều chỉnh (tuning) và cải thiện hiệu suất của ModSecurity:

- Tinh chỉnh các quy tắc có sẵn: Người quản trị có thể điều chỉnh các quy tắc có sẵn trong Core Rule Set bằng cách thay đổi các điều kiện hoặc tham số để giảm thiểu số lượng false positive. Việc này đòi hỏi hiểu biết sâu rộng về hoạt động của ứng dụng và mối đe dọa tiềm ẩn.
- Loại bỏ các quy tắc không cần thiết: Đôi khi, có những quy tắc trong Core Rule Set không phù hợp hoặc không cần thiết cho môi trường cụ thể của hệ thống. Loại bỏ các quy tắc không cần thiết này có thể giảm thiểu số lượng false positive một cách đáng kể.
- Tạo các quy tắc tùy chỉnh (custom rules): Tạo các quy tắc tùy chỉnh cho phép người quản trị mạng xác định các mẫu hoạt động đáng nghi và đặt các biện pháp phòng ngừa cụ thể. Việc này giúp tăng cường khả năng phát hiện và giảm thiểu false positive bằng cách điều chỉnh chính sách bảo mật theo nhu cầu cụ thể của hệ thống.
- Sử dụng machine learning và AI: Kết hợp ModSecurity với các kỹ thuật machine learning và trí tuệ nhân tạo có thể giúp phát hiện các mẫu hoạt động không bình thường một cách tự động và hiệu quả hơn, từ đó giảm thiểu false positive và tăng cường bảo mật hệ thống mạng.

a. Improve Mod Security with custom rule:

Để có thể tạo được các rule custom theo nhu cầu, ta cần hiểu rõ về cấu trúc bộ quy tắc (rule) của Mod Security. Rule engine của ModSecurity, cho phép người quản trị tạo và tùy chỉnh các quy tắc để phát hiện và xử lý các mẫu tấn công phổ biến và cụ thể cho ứng dụng cụ thể của họ. Cú pháp:

```
SecRule VARIABLES OPERATOR ACTIONS
```

Ví dụ:

```
SecRule ARGS "<script>" log,deny,status:404
```

Trong đó:

VARIABLES: là một tập hợp các biến đầu vào được trích xuất từ request, cung cấp thông tin cho Mod Security. Các thông tin này có thể là request header, URI,...

OPERATOR: cung cấp cho ModSecurity cách tìm kiếm và so khớp rule

ACTIONS: các hành động sẽ thực hiện khi rule được so khớp thành công. Các hành động này có thể là ghi log, chặn, trả về status code,...

Task: Tìm hiểu cách viết rule, giải thích ý nghĩa của ít nhất 3 rule trong bộ Core Rule Set

Task: Chỉnh sửa hoặc viết mới 3 custom rule và thử nghiệm lại rule trên web DVWA.

Một vài gợi ý:

- Chặn từ một từ khoá nhất định trong form/url
- Chặn lượt truy cập tới web server từ một địa chỉ IP
- Giới hạn dung lượng upload của một file

b. Improve Mod Security with AI:

Việc kết hợp ModSecurity với trí tuệ nhân tạo (AI) đang mở ra một tiềm năng lớn trong việc cải thiện khả năng bảo mật của hệ thống mạng. AI có khả năng học từ dữ liệu lịch sử và tự động điều chỉnh mô hình để phát hiện ra các mẫu và xu hướng phức tạp hơn mà có thể bỏ qua bởi các phương pháp truyền thống. Kết hợp ModSecurity với AI giúp tăng cường khả năng phát hiện các mối đe dọa mạng và giảm thiểu số lượng false positive.

Có nhiều cách khác nhau để kết hợp trí tuệ nhân tạo với ModSecurity. Một trong những cách tiếp cận đáng chú ý để kết hợp trí tuệ nhân tạo (AI) với ModSecurity là sử dụng điểm bất thường (anomaly score) của các quy tắc trong bộ Core Rule Set như một đặc trưng cho việc huấn luyện mô hình AI. Điều này có thể được thực hiện bằng cách kết hợp điểm bất thường với các đặc trưng khác được trích xuất từ giao thức HTTP transaction, như các thông tin về URL, phương thức HTTP, tiêu đề, thân nội dung (body), và thậm chí là thông tin về người gửi và người nhận. Bằng cách tạo thành một bộ đặc trưng huấn luyện AI từ điểm bất thường và các thông tin từ HTTP transaction, ta có thể xây dựng một mô hình AI có khả năng học và nhận biết các mẫu hành vi bất thường và tiềm ẩn trên mạng. Mô hình này có thể được sử dụng để phát hiện ra các cuộc tấn công và mối đe dọa mạng một cách tự động và hiệu quả hơn, từ đó giảm thiểu số lượng false positive và tăng cường bảo mật của hệ thống.

Ngoài ra, một cách tiếp cận khác là sử dụng các đoạn script để thực hiện việc truy xuất các thông tin của một HTTP request mà có điểm bất thường cao hơn một ngưỡng nhất định. Thông tin này sau đó có thể được sử dụng để tiến hành đánh giá lại và phân tích chi tiết về request đó trước khi thực hiện các hành động tiếp theo, như chặn hoặc ghi log. Điều này giúp đảm bảo rằng các hành động được thực hiện chỉ dựa trên các dữ liệu chính xác và đáng tin cậy, từ đó giảm thiểu rủi ro của việc chặn nhầm các request hợp lệ.

Bonus: Tham khảo các tài liệu sau, tiến hành cài đặt và thử nghiệm việc kết hợp AI vào ModSecurity:

- <https://github.com/ngoctint11vc/waf>
- <https://github.com/coreruleset/machine-learning-integration-plugin>

D. YÊU CẦU & ĐÁNH GIÁ

- Sinh viên tìm hiểu và thực hành theo hướng dẫn, thực hiện theo nhóm đã đăng ký.

- Nộp báo cáo kết quả gồm chi tiết những việc (Report) mà nhóm đã thực hiện, quan sát thấy và kèm ảnh chụp màn hình kết quả (nếu có); giải thích cho quan sát (nếu có).
- Báo cáo:
 - File .PDF. Tập trung vào nội dung, không mô tả lý thuyết.
 - Đặt tên theo định dạng: [Mã lớp]-LabX_MSSV1_MSSV2.
 - Ví dụ: [NT534.K11.ANTN.1]-Lab1_1852xxxx_1852yyyy.
 - Nếu báo cáo có nhiều file, nén tất cả file vào file .ZIP với cùng tên file báo cáo.
 - Nộp file báo cáo trên theo thời gian đã thống nhất tại courses.uit.edu.vn.

Bài sao chép, trộm, ... sẽ được xử lý tùy mức độ vi phạm.

HẾT

Chúc các bạn hoàn thành tốt!